IT Risk Management Policy

Effective Date:
June 10, 2026

Category:
Security

Scheduled Review:
June 2027

1. Authority

Executive Order 2016-06, Enterprise Information Technology Governance

2. Document Control

This document replaces, in its entirety, the *IT Risk Management Policy*, dated January 2, 2025.

3. Purpose

This policy establishes the framework for managing information technology (IT) risks within the Commonwealth. It aims to protect the confidentiality, integrity and availability of Commonwealth IT assets and ensure compliance with legal, regulatory, and operational requirements.

4. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies"). Third-party vendors, licensors, contractors, or suppliers shall meet the policy requirements of this policy as outlined herein.

5. Policy

5.1 Risk Management

The Commonwealth is committed to proactively managing IT risks to protect its information assets, maintain operational continuity, and ensure compliance with applicable legal, regulatory, and contractual obligations. All IT systems, applications and data will be subject to a risk management process to identify vulnerabilities, assess potential impacts and implement appropriate controls.

5.1.1 Key Principles

Risk Identification - Identify potential IT risks, including cybersecurity threats, operational disruptions, and technology failures, through monitoring and assessments.

Risk Assessment - Assess risk based on their likelihood and potential impact on

confidentiality, integrity, and availability of information assets.

Risk Mitigation and Treatment - Implement risk mitigation strategies, including preventative, detective, and corrective controls, to address identified risks in alignment with Commonwealth priorities.

Compliance and Standards - Ensure alignment with relevant standards, such as NIST framework.

Monitoring and Reporting - Establish continuous monitoring mechanisms and regular reporting of risk management activities to senior leadership.

Training and Awareness - Provide training and awareness to promote a culture of risk awareness among staff and stakeholders.

5.2 IT Vendor Risk Management & Risk Assessment

The Commonwealth recognizes that third-party vendors play a critical role in its IT operations. To protect information assets and maintain a reasonable level of assurance from a security and compliance perspective, the Commonwealth is committed to managing inherent risks presented by IT vendors and their IT products and services through a structured vendor risk assessment process, known as an IT Vendor Risk Assessment.

Prior to the procurement or use of any new Computing Service, an IT Vendor Risk Assessment shall be conducted by the Governance, Risk and Compliance team, following the process outlined in the IT Risk Management Vendor Risk Assessment Procedure.

A new IT Vendor Risk Assessment is required when a change to previously reviewed services or a change in the scope of services provided.

Additionally, any new Computing Services that an agency would like to test via a Pilot or Proof of Concept must be approved by the Department of General Services (DGS). Guidance on this may be found within the *DGS, Bureau of Procurement Policy Directive 2021-1, New Technology Pilot Program and Product Demonstrations*.

5.3 System and Organization Control (SOC) Reporting

SOC is a term defined by the American Institute of Certified Public Accountants (AICPA). There are three primary types of reports. The reports are designed to address different aspects of a service organization's control environment.

1. SOC 1- Internal Control Over Financial Reporting

    - SOC 1 Type I – Report on the suitability of the design of the controls at a specific point in time.
    - SOC 1 Type II - Report on the suitability of the design of the controls over a period of time.

2. SOC 2 – Trust Service Criteria (Security, Confidentiality, Integrity, Availability and Privacy)

    - SOC 2 Type I – Report on the suitability of the design of the controls at a specific point in time.
    - SOC 2 Type II - Report on the suitability of the design of the controls over a period of time.

3. SOC 3 – General Use Report (high level summary usually intended for marketing purposes)

Agencies and Service Organizations shall obtain their provider's most recent, applicable SOC report and follow SOC review requirements outlined in the IT Risk Management SOC Report Review Procedure.

SOC reports and related supporting documentation obtained from service organizations, vendors, licensors, contractors, suppliers, or other third parties shall be protected as confidential. Requests for SOC reports under the Pennsylvania Right-to-Know Law may be denied or redacted where applicable exemptions apply, including Sections 708(b)(3), 708(b)(4), and 708(b)(11).4.4 Risk Acceptance and Acknowledgement

The Governance, Risk and Compliance team will review the appropriate risk acknowledgment form upon identification of potential risk. The identified risks will be shared with the Commonwealth Chief Information Officer (CIO) and Deputy Chief Information Officer (CIO), the Commonwealth Chief Information Security Officer (CISO), the Delivery Center/Agency Information Security Officer (ISO) and identified Business Owner for initial discussion. Recommendations will be documented by the Technical Security Risk and Governance Manager and processed for signature asset forth below.

- Agency Deputy Secretary for Administration, Executive Deputy Secretary, or Agency Secretary
    - For risks considered critical or high-risk, signature certifies an understanding and acknowledgement of the risks outlined within the form and that in the event an issue arises, they will acknowledge responsibility.
- Agency Office of Chief Counsel
    - For risks considered critical or high-risk, signature certifies that they have been consulted in connection with the risks outlined within the form and that they have advised the agency and delivery center of the potential legal concerns associated with the risks identified.
- Agency Business Area Contact (Bureau Director)
    - For all levels of risk, signature certifies an understanding and acknowledgement of the risks outlined within the form and that in the event an issue arises, they will acknowledge responsibility.

5. Contact

Questions or comments may be directed via email to OA, IT Policy.

6. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

Version	Date	Purpose of Revision
Original	01/2/2025	Base Document
Revision	06/10/2026	Removed Roles and Responsibilities Section Clarifications and updates related to the revised IT Risk Acknowledgement form Added language regarding SOC report confidentiality